Secure Python Service Standard

Engineering standard ES-PY-01 · Version 2.3 · Effective 1 August 2026 · Applies to all Python backend services

> Fictional sample document for testing a domain-specialist RAG. Rule IDs are referenced in code reviews as, for example, "violates SEC-11".

1. Purpose and scope

This standard defines the minimum security and code quality rules for Python services that handle customer data or run in production. Rules marked **SEC** are security requirements and block a merge. Rules marked **CR** are code review requirements; reviewers may accept a documented exception.

2. Secrets management

SEC-01 Secrets (API keys, passwords, tokens, private keys, connection strings with credentials) must never appear in source code, configuration files in the repository, container images or test fixtures. Load them at runtime from the secrets manager or from environment variables injected by the platform.

SEC-02 Secrets must never be written to logs, error messages, metrics labels or exception traces. Mask them as `****` and show at most the last 4 characters.

SEC-03 Every secret is rotated at least every 90 days, and immediately after any suspected exposure, including a secret committed to Git even if the commit was reverted.

3. Input handling and injection

SEC-10 All SQL must use parameterised queries or the ORM. Building SQL with f-strings, `%` formatting, `.format()` or string concatenation is forbidden, including for table and column names; use an allow-list for identifiers.

```
# Non-compliant (SEC-10)
cur.execute(f"SELECT * FROM orders WHERE customer_id = {customer_id}")

# Compliant
cur.execute("SELECT * FROM orders WHERE customer_id = %s", (customer_id,))
```

SEC-11 Never call `subprocess` with `shell=True` and never use `os.system` or `os.popen`. Pass the command as a list of arguments and validate every user-controlled argument against an allow-list.

SEC-12 `eval`, `exec` and `compile` on data that is not a hard-coded literal are forbidden.

SEC-13 Deserialise untrusted data only with safe formats: JSON, or YAML through `yaml.safe_load`. `pickle`, `marshal` and `yaml.load` without `SafeLoader` must never read data from users, queues or external storage.

SEC-14 Validate every request body with a schema (Pydantic models) at the service boundary. Reject unknown fields. Limit string fields to 10,000 characters and request bodies to 1 MB unless an exception is documented.

SEC-15 Outbound HTTP requests to URLs influenced by users must go through the egress proxy and must be checked against an allow-list of hosts, to prevent server-side request forgery (SSRF).

4. Authentication, tokens and passwords

SEC-20 Generate tokens, session identifiers and reset codes with the `secrets` module, with at least 32 bytes of randomness (`secrets.token_urlsafe(32)`). The `random` module must not be used for anything security related.

SEC-21 Store passwords only as Argon2id hashes with parameters memory 64 MiB, iterations 3, parallelism 4. MD5, SHA-1 and unsalted SHA-256 are forbidden for passwords.

SEC-22 Access tokens (JWT) expire after at most 15 minutes. Refresh tokens expire after at most 7 days and are rotated on every use. Tokens are signed with RS256 or EdDSA; HS256 is allowed only for service-internal tokens.

SEC-23 Every endpoint enforces authorisation on the server for the specific resource requested (object-level checks). Hiding a button in the UI is not access control.

5. Transport and network

SEC-30 All network traffic uses TLS 1.2 or newer. Certificate verification must never be disabled (`verify=False`), including in staging.

SEC-31 Every outbound network call sets an explicit timeout. The default is 10 seconds for HTTP calls and 5 seconds for database connections.

SEC-32 Services listen on 127.0.0.1 or the pod network only; binding to 0.0.0.0 on a host network requires a security review.

6. Logging and privacy

SEC-40 Logs are structured JSON with the fields timestamp, level, service, trace_id and message. Personal data (names, emails, phone numbers, government IDs) must not be logged; log a hashed customer_id instead.

SEC-41 Application logs are kept for 30 days and audit logs for 1 year.

SEC-42 Debug mode (`debug=True`, verbose stack traces returned to clients) must never be enabled in production.

7. Reliability rules

CR-01 Retries use exponential backoff with jitter: at most 3 attempts, base delay 200

milliseconds, maximum delay 5 seconds. Only idempotent operations may be retried automatically.

```
@retry(stop=stop_after_attempt(3), wait=wait_random_exponential(multiplier=0.2, max=5))
def fetch_invoice(invoice_id: str) -> Invoice: ...
```

CR-02 Bare `except:` and `except Exception: pass` are not allowed. Catch specific exceptions, log them with the trace_id and re-raise or return a clear error.

CR-03 Every external dependency call is wrapped with a circuit breaker that opens after 5 consecutive failures and stays open for 30 seconds.

8. Code review rules

Rule	Requirement
CR-10	Functions stay under 50 lines; split longer functions unless the reviewer accepts the reason.
CR-11	All public functions and methods have type hints, and the service passes `mypy --strict`.
CR-12	Changed code has at least 80% line coverage from tests. Bug fixes include a test that fails before the fix.
CR-13	Pull requests change at most 400 lines, excluding generated files and lock files.
CR-14	Changes to authentication, payments or cryptography need two approvals, one from the security guild.
CR-15	No commented-out code and no TODO without a ticket reference, for example `TODO(PAY-123)`.

9. Dependencies

CR-20 Pin every direct dependency to an exact version in the lock file. Update dependencies at least once a month.

SEC-50 CI runs `pip-audit` on every build. Critical vulnerabilities are fixed within 7 days, high within 30 days, medium within 90 days.

10. AI and LLM features

SEC-60 Content retrieved from documents, web pages, tickets or tool results is untrusted input. It is wrapped in delimiters and never treated as instructions to the model.

SEC-61 Model output is never executed as code, SQL or shell commands, and never rendered as HTML without escaping.

SEC-62 AI agents run tools with the permissions of the requesting user. Actions with side effects (payments, deletes, external messages) require human approval.

SEC-63 Before release, every LLM feature is tested against the prompt-injection test suite, including indirect injection hidden in documents.

11. Exceptions

Exceptions to CR rules are recorded in the pull request description. Exceptions to SEC rules need written approval from the security guild, expire after 90 days and are listed in the service's SECURITY.md.